

سياسة إدارة الاصول

قياس التحول الرقمي 2023

اعتمادات وكالة التحول الرقمي والمدن الذكية بأمانة جازان

الاعتماد

سعادة وكيل الأمين للتحول الرقمي والمدن الذكية
م. عبد الرحمن بن إبراهيم الساحلي



سياسة إدارة الاصول

النسخة: ١,١

٢٠٢٢/٠٦/٠٦ م

١٤٤٣/١١/٠٧ هـ

التصنيف: داخلي

جميع الحقوق محفوظة.

لا يمكن أن يتم تصوير أو نقل الكتروني أو تعديل أو إعادة إنتاج لأي جزء من هذه الوثيقة بأي شكل.

تفاصيل الوثيقة

وثيقة التحكم في إصدارات

النسخة	التاريخ	المراجع	تعليقات
١,٠	١٤٤٣/٥/١٣ هـ	ضوابط الهيئة الوطنية للأمن السيبراني ECC1:٢٠١٨ معيار ISO٢٧٠٠١/٢٠١٣	
١,١	١٤٤٣/١١/٧ هـ	معيار NIST SP ٨٠٠-٥٦ معيار COBIT ٥ for Information Security	مراجعة الوثيقة وتحديثها لتتوافق مع معايير الهيئة الوطنية للأمن السيبراني

اعتماد الوثيقة

الموضوع: بشأن اجتماع اللجنة الإشرافية للأمن السيبراني
للمراجعة الدورية للسياسات الفرعية.

مختصر الاجتماع

أنه في يوم الاثنين الموافق ١٤٤٣/١١/٧ هـ، تم اجتماع اللجنة الإشرافية للأمن السيبراني بحضور شكل من:

- | | |
|---|----------------------|
| ١- المهندس / إبراهيم بن طاهر ككريري | عضواً ونائباً للرئيس |
| ٢- الأستاذ / إبراهيم بن محمد العسيري | عضو |
| ٣- الأستاذ / عبدالرحمن بن إبراهيم ساحلي | عضو |
| ٤- الأستاذ / محمد بن علي عسيري | عضو |
| ٥- الأستاذ / علي بن أحمد جعفري | عضو وأميناً للجنة |
- وذلك بعد المراجعة الدورية للسياسات الفرعية المعتمدة حسب متطلبات الهيئة الوطنية للأمن السيبراني وهي كالتالي :
- سياسة إدارة حوادث وتهديدات الأمن السيبراني
 - سياسة أمن العمليات التشغيلية والشبكات
 - سياسة الأمن المادي
 - سياسة السرية والخصوصية وعدم الإهشاء
 - سياسة الأمن السيبراني لإدارة الأطراف الخارجية
 - سياسة إدارة الثغرات واختبارات الاختراق
 - سياسة الاستخدام المقبول
 - سياسة تطوير التطبيقات والنظم
 - سياسة إدارة الأصول
 - سياسة الأمن السيبراني المتعلق بخدمات الحوسبة السحابية والاستضافة
 - سياسة التشفير
 - سياسة الموارد البشرية
 - سياسة إدارة الهوية والدخول

وقد أقرت اللجنة التعديلات على السياسات وتحديثها بما يتناسب مع متطلبات الهيئة الوطنية للأمن السيبراني تمهيداً لرفعها لسماعة رئيس اللجنة الإشرافية للأمن السيبراني لاعتمادها أو توجيهه بما يرى.

عضو وأمين اللجنة: علي أحمد جعفري
عضو اللجنة: محمد بن علي عسيري
عضو اللجنة: عبدالرحمن بن إبراهيم ساحلي
عضو اللجنة: إبراهيم بن محمد العسيري
نائب رئيس اللجنة الإشرافية: م. إبراهيم بن طاهر ككريري



تربو سوليوشن للبرمجيات
Turbo Solution

الفهرس

- ١- النطاق..خطأ! الإشارة المرجعية غير معروفة.
- ٢- ملكية الوثيقة ٤
- ٣- التعريفات / الاختصارات ٤
- ٤- سياسة إدارة الاصول ٥
- ٥- استعراض السياسة ٩
- ٦- الأنظمة والمعايير ٩
- ٧- الوثائق الداعمة ٩

لج

١- النطاق

تغطي هذه السياسة جميع أصول أمانة منطقة جازان المعلوماتية وتشمل تحديد الأصول والمسؤولية عن الأصول والاستخدام المقبول للأصول وتصنيف الأصول وترميزها. وتطبق على المستخدمين ومن ضمنهم:

- موظفي أمانة منطقة جازان.
 - الموظفين المتعاقدين.
 - الأطراف الخارجية.
- يجب على جميع المستخدمين قراءة وفهم والالتزام بهذه السياسة وبسياسات الأمن السيبراني الأخرى ذات الصلة.

٢- ملكية الوثيقة

تتولى الإدارة العامة للأمن السيبراني في أمانة منطقة جازان ملكية هذه الوثيقة، ويجب الحصول على موافقة مدير الإدارة العامة للأمن السيبراني الصريحة واعتماد اللجنة الإشرافية للأمن السيبراني على أي تغييرات أو تحديثات على هذه الوثيقة.

٣- التعريفات / الاختصارات

المصطلح	التعريف
الأمن السيبراني	الأمن السيبراني هو حماية الشبكات وأنظمة تقنية المعلومات وأنظمة التقنيات التشغيلية، ومكوناتها من أجهزة وبرمجيات، وما تقدمه من خدمات، وما تحتويه من بيانات، من أي اختراق أو تعطيل أو تعديل أو دخول أو استخدام أو استغلال غير مشروع. ويشمل مفهوم الأمن السيبراني أمن المعلومات والأمن الإلكتروني والأمن الرقمي ونحو ذلك.
الأصل	أي شيء ملموس أو غير ملموس له قيمة بالنسبة للأمانة. هناك أنواع كثيرة من الأصول؛ بعض هذه الأصول تتضمن أشياء واضحة، مثل: الأشخاص، والآلات، والمرافق، وبراءات الاختراع، والبرمجيات والخدمات. ويمكن أن يشمل المصطلح أيضاً أشياء أقل وضوحاً، مثل: المعلومات والخصائص (مثل: سمعة الأمانة وصورتها العامة، أو المهارة والمعرفة).
سياسة	وثيقة تحدد بنودها التزاماً عاماً أو توجيهاً أوتية ما أو كما يتم التعبير عنها من قبل صاحب الصلاحية. سياسة الأمن السيبراني هي وثيقة تعبر بنودها عن الالتزام الرسمي للإدارة العليا للأمانة بتنفيذ وتحسين برنامج الأمن السيبراني في الأمانة، وتشتمل السياسة على أهداف الأمانة فيما يتعلق ببرنامج الأمن السيبراني وضوابطه ومتطلباته وآلية تحسينه وتطويره.
تقنية المعلومات	الإدارة العامة للتحويل الرقمي
مسؤول الأعمال	الموظف المسؤول عن تصنيف البيانات والأصول التي تحتضن منتجات الأعمال ومراجعة سجلات وصلاحيات الوصول
المسؤول التقني	الموظف المسؤول عن إدارة وتشغيل وصيانة ومراقبة أداء الأنظمة ومساعدة مسؤول الأعمال على مراجعة سجلات صلاحية الوصول

٤. سياسة إدارة الأصول

٤.١.١. المسؤولية عن الأصول

- ٤.١.١.١ يجب على تربو سوليوشن امتلاك وحفظ وإدارة مخزن أو سجل يحتوي على كافة الأصول المعلوماتية الملموسة وغير الملموسة، الثابتة والمتحركة، بما في ذلك أصول البيانات والرخص والبرمجيات والتطبيقات والنظم الافتراضية.
- ٤.١.١.٢ يجب العمل على حفظ الأصول المعلوماتية المهمة في تربو سوليوشن وتحديثها.
- ٤.١.١.٣ يجوز استثناء بعض الأصول التي تستبدل بشكل متكرر، وتدار بالكميات مثل لوحات المفاتيح وأجهزة الفأرة والأسلاك، وغيرها التي لا تشكل مخاطر على الأمن السيبراني.
- ٤.١.١.٤ يجب الحفاظ على قاعدة بيانات لإدارة الاعدادات (CMDB) كجزء من نظام إدارة الإعدادات (Configuration Management System) يحتوي على العلاقات بين الأصول المعلوماتية ومربوط. مع سجل الأصول (Asset Register)، بهدف تحقيق عدة متطلبات للأمن السيبراني مثل الأثر عند تنفيذ تغييرات والاستجابة للحوادث ومراقبة الخدمات.
- ٤.١.١.٥ على جميع موظفي تربو سوليوشن والمتعاقدين والمستشارين وموظفي الأطراف الخارجية الامتثال لسياسة الاستعمال المقبول في تربو سوليوشن بما في ذلك قواعد استعمال الانترنت والبريد الالكتروني والأجهزة الشخصية.
- ٤.١.١.٦ يجب على تقنية المعلومات تبني إجراء معتمد لإدارة الأصول لتسجيل وحفظ وتحديث الأصول المملوكة لتربو سوليوشن والمدارة من قبلها وبما يتوافق مع متطلبات الإدارة العامة للأمن السيبراني. ويجب تصنيف هذه الأصول إلى معدات أو أجهزة أو نظم أو تطبيقات أو برمجيات أو رخص أو معلومات، الخ.
- ٤.١.١.٧ سجل الأصول يجب أن يحتوي على حقول معلومات مثل التعريف والوصف والمالك (Owner) والوصي على الأصل (Asset Custodian) والموقع والتصنيف والترميز.
- ٤.١.١.٨ فيما يتعلق بالأصول وحمايتها، يجب على تربو سوليوشن تبني سياسات تشجع وتعزز قيم النزاهة والثقة وتحمل المسؤولية بما لا يتعارض مع القيم العامة للوزارة.
- ٤.١.١.٩ يجب استعمال الأصول بما يخدم أعمال تربو سوليوشن.
- ٤.١.١.١٠ يجب على كافة الموظفين المعنيين الإقرار بضرورة حفظ الأصول في عملهم بما يتماشى ويمتثل مع السياسات والأطر ذات العلاقة.
- ٤.١.١.١١ يجب على تربو سوليوشن التأكد من استعادة كافة الأصول المعلوماتية - بما فيها البيانات - التي بحوزة الموظفين في حال انتهاء الخدمة أو تغيير في الأدوار أو النقل الوظيفي، ويشمل ذلك على سبيل المثال لا الحصر، إجراء معتمد لتدقيق قوائم مراجعة ضد الجرد للمقتنيات وإجراء معتمد لإتلاف البيانات.
- ٤.١.١.١٢ يجب على تقنية المعلومات الاحتفاظ بقائمة محدثة سنوياً لجميع الأصول التابعة للأنظمة الحساسة يجب على الإدارة العامة للأمن السيبراني التأكد من تحديد ملاك الأصول (Assets Owner) والتأكد من إشراكهم في دورة حياة إدارة الأصول، التابعة للأنظمة الحساسة.



٤,١,٢. ملكية الأصول

الدور	المسؤوليات
مالك الأصل (Asset Owner) (مدراء الإدارات، والذين يكون لهم مسؤوليات رئيسية عن الأصول المعلوماتية المرتبطة بالمهام الوظيفية الخاصة بصلاحياتهم الوظيفية)	✓ تحديد الأصول المعلوماتية. ✓ تصنيف الأصول المعلوماتية. ✓ ضمان القيام بعملية عنونة ملائمة للمعلومات الحساسة. ✓ مراجعة تصنيف الأصول المعلوماتية. ✓ ضمان وضع "الأوصياء" على الأصول، و"مستخدمي" هذه الأصول بالصورة حول ضوابط ومتطلبات الحماية.
الأوصياء على الأصول (Asset Custodian) (المسؤول التقني أو مزود الخدمة، أو أولئك الذين يتم تعيينهم من قبل مالك الأصل)	✓ حماية المعلومات لضمان سريتها ودقتها وتوافرها. ✓ تطبيق سياسات الأمن السيبراني وأفضل الممارسات على الأصول. ✓ تحديد وتوثيق متطلبات منح التفويض بالدخول إلى الأصول. ✓ توفير نسخ احتياطية عن المعلومات واستعادتها. ✓ كشف المخالفات والانتهاكات ونقاط الضعف الأمنية والتعامل معها. ✓ مراقبة الالتزام بسياسات الأمن السيبراني وبأفضل الممارسات. ✓ إبلاغ مالك المعلومات عن أي مخالفات أمنية، أو انتهاكات أمنية، أو حوادث تعرض المعلومات للخطر، سواء كانت هذه المخالفات والانتهاكات فعلية، أو يوجد شك بحدوثها.
مستخدمو الأصول (الأفراد، أو المجموعات، أو الهيئات المخولة من قبل المالك بالدخول إلى الأصول المعلوماتية)	✓ استيعاب وفهم التصنيفات الأمنية، والتقيّد بالضوابط التي حددها المالك وطبقها الأوصياء على الأصول. ✓ إدامة وحفظ تصنيفات المعلومات وطرق عنونتها التي وضعها المالك. ✓ الاتصال بالمالك عندما تكون المعلومات غير معنونة، أو عند عدم معرفة التصنيف. ✓ إبلاغ الوصي على المعلومات أو مالك المعلومات، عن أي مخالفات أمنية، أو انتهاكات أمنية، أو حوادث تُعرض المعلومات للخطر، سواء أكانت هذه المخالفات والانتهاكات فعلية، أو يوجد شك باحتمال حدوثها.

٤,٢. تصنيف وترميز المعلومات والبيانات

٤,٢,١. يجب على مالك الأصل تصنيف الأصول المعلوماتية بحسب قيمة المعلومات ودرجة حساسيتها ومتطلبات السرية والخصوصية.

٤,٢,٢. يجب على مالك الأصل تقييم المخاطر على الأصول المعلوماتية بما فيه تقدير الخسائر والأضرار الناجمة عن فقدانها، سواء الخسائر المالية أو السمعة أو العلامة التجارية أو المساءلة القانونية، الخ.

٤,٢,٣. يجب على مالك الأصل تصنيف البيانات المنتجة داخليا أو خارجيا بحسب أحد التصنيفات التالية:

التصنيف	الوصف
سري للغاية	تصنيف البيانات ذات الحساسية الأكبر والقيمة الأعلى والتي يجب استعمالها بأعلى درجات الضبط، حيث أن أي خروقات أو إفشاء لها يترتب عليه تبعات سلبية عالية جدا على أمانة منطقة جازان أو أصحاب العلاقة. الآثار السلبية تكون هي الأشد وبشكل مباشر.
سري	تصنيف البيانات ذات الحساسية كبيرة وقيمة مرتفعة والتي يجب استعمالها بدرجات ضبط قوية، حيث أن أي خروقات أو إفشاء، لها تبعات سلبية على أمانة منطقة جازان أو أصحاب العلاقة.
استعمال داخلي	البيانات التي يجوز توزيعها ومشاركتها داخليا فقط ولا يترتب عليها آثار سلبية على أمانة منطقة جازان في حال نشرها داخل أمانة منطقة جازان لأصحاب العلاقة.
عام	أي بيانات أو معلومات يمكن تعميمها بواسطة الجهات المخولة بذلك للعام.

- ٤,٢,٤. في حالات تعدد مجموعة بيانات ذات تصنيف مختلف، يتم الأخذ بالتصنيف الأعلى.
- ٤,٢,٥. يجب على مالك الأصل ترميز كافة الأصول بملكيته مع المحافظة على سجل الرموز بحسب إجراء الترميز المتبع في وزارة الشؤون البلدية والقروية.
- ٤,٢,٦. يجب حفظ كافة الوثائق التي تحتوي بيانات مصنفة بـ "سري للغاية" أو "سري" في أماكن آمنة مثل الكابن أو الأدراج المقفلة، وأن يتم إغلاق المكاتب التي تحتوي هذه الوثائق في حال كانت فارغة والحرص على أمان مفاتيح غرف الأرشفة.
- ٤,٢,٧. يجب حفظ كافة الوثائق التي تحتوي بيانات مصنفة بـ "الاستعمال الداخلي" في أماكن بدرجة مناسبة من الأمان والحرص على عدم تركها مكشوفة.
- ٤,٢,٨. أي أصول مادية وعند تصنيفها وترميزها، يجب أن يتم وضع بطاقة للتعريف لها.
- ٤,٢,٩. يجب إضافة الأصول الجديدة إلى سجل الأصول والتأكد من إدراج هذا الإجراء في الإجراءات الداخلية لدى مسؤول الأعمال والمسؤول التقني.
- ٤,٢,١٠. يجب تحديد المسؤول عن متابعة وتحديث سجل الأصول وتقنين صلاحية الوصول والتعديل عليه.
- ٤,٢,١١. يجب على الإدارة العامة للأمن السبراني التأكد من تصنيف جميع بيانات الأنظمة الحساسة.
- ٤,٢,١٢. يجب على الإدارة العامة للأمن السبراني حماية البيانات المصنفة الخاصة بالأنظمة الحساسة من خلال تقنيات، منع تسريب البيانات (Data Leakage Prevention).
- ٤,٢,١٣. يجب على تقنية المعلومات تحديد مدة الاحتفاظ المطلوبة (Retention Period) لبيانات الأعمال المتعلقة بالأنظمة الحساسة؛ حسب التشريعات ذات العلاقة، ويتم الاحتفاظ بالبيانات المطلوبة فقط، في بيئات الإنتاج للأنظمة الحساسة ويمنع نقل أي من بيانات بيئة الإنتاج الخاصة بالأنظمة الحساسة إلى أي بيئة أخرى.
- ٤,٢,١٤. يجب على تقنية المعلومات عدم استخدام بيانات الأنظمة الحساسة في غير بيئة الإنتاج (Production Environment) إلا بعد استخدام ضوابط مشددة لحماية تلك البيانات مثل: تقنيات تعقيم البيانات Data Masking أو تقنيات مزج البيانات (Data Scrambling).
- ٤,٢,١٥. يجب تصنيف البيانات والمعلومات وآلية ترميزها (Classification and Labeling Mechanisms)

٥- استعراض السياسة

على اللجنة الإشرافية للأمن السيبراني مراجعة سياسة الأمن السيبراني كل سنة أو عند الحاجة مع أخذ المدخلات التالية في عين الاعتبار:

- نتائج تقييم المخاطر والتغيرات في المخاطر
- مخرجات مراجعة الإدارة العامة للأمن السيبراني
- التغيرات في التشريعات الحكومية
- مبادرات القطاع البلدي الجديدة
- التغييرات في البيئة وإدخال تقنيات جديدة
- تقارير حوادث الأمن
- تقرير دراسة الاستثناءات
- السياسات التفصيلية لعناصر السياسة والمبادئ التوجيهية يتم مراجعتها كل سنة أو عند الحاجة

٦- الانظمة والمعايير

- معيار الهيئة الوطنية للأمن السيبراني
- معيار الايزو ٢٧٠٠١
- معيار NIST SP ٨٠٠-٥٦
- معيار COBIT ٥ for Information Security

٧- الوثائق الداعمة

- السياسة العامة للأمن السيبراني

